

REPORT FINAL — DVWA SQL Injection Assessment (MEDIUM)

Comprehensive cybersecurity lab report documenting SQL Injection exploitation, enumeration, comparison and detection opportunities inside DVWA running on Metasploitable 2.

1. Executive Summary

This assessment evaluated SQL Injection exposure in DVWA configured at MEDIUM security level. The objective was to validate whether defensive changes introduced between LOW and MEDIUM altered exploitability. Testing confirmed that exploitation remained possible after adapting payloads and using enumeration techniques.

2. Scope & Lab Environment

Role	Technology
Attacker	Kali Linux
Target	Metasploitable 2
Application	DVWA
Vulnerability	SQL Injection
Security Mode	MEDIUM

3. Methodology

- Reconnaissance and initial validation.
- Boolean-based testing (true/false conditions).
- UNION SELECT validation and column alignment.
- Database discovery using version() and database().
- Schema enumeration using information_schema.
- Credential disclosure validation.

4. Commands Used

```
1 AND 1=1
1 AND 1=2
1 UNION SELECT version(),database()
1 UNION SELECT table_name,table_schema FROM information_schema.tables
1 UNION SELECT column_name,table_name FROM information_schema.columns WHERE table_name=0x7573657273
1 UNION SELECT user,password FROM users
```

5. Technical Findings & Risk Matrix

Finding	Impact	Severity
Boolean SQLi	Query manipulation	Medium
UNION SQLi	Data extraction	High
Schema Enumeration	Internal discovery	High
Credential Disclosure	Sensitive exposure	Critical

6. LOW vs MEDIUM Comparative Analysis

Difficulty Comparison

LOW



MEDIUM



LOW permitted straightforward payload execution. MEDIUM introduced partial filtering and behavioral changes. Despite this, SQLi remained exploitable through payload tuning, numeric injection and hexadecimal encoding techniques.

7. Detection Opportunities (Blue Team View)

- Repeated boolean probes (1=1 / 1=2).
- UNION SELECT signatures.
- information_schema access attempts.
- High entropy or encoded payloads.
- Unusual application database queries.

8. Lessons Learned

- Security level changes do not automatically remove root causes.
- Enumeration is a structured offensive phase, not random guessing.
- SQL fundamentals are essential for AppSec and Pentesting.
- SOC analysts can build detections around behavioral indicators.
- Understanding databases improves both attack and defense.

9. Keywords

SQL Injection, DVWA, Web Application Security, AppSec, Pentesting, Enumeration, UNION SQLi, Detection Engineering, OWASP, Credential Disclosure.

10. Final Conclusion

The exercise demonstrated realistic offensive adaptation between security levels. MEDIUM increased operational difficulty but did not prevent exploitation. The lab strengthened practical SQL knowledge, web security understanding, offensive methodology and blue team detection awareness.